

INFORME DE SEGURIDAD: CUMPLIMIENTO DE LA POLÍTICA DE CONTRASEÑAS

Fecha: 11 de septiembre de 2026

Analistas de seguridad: Leonardo de Carvalho y Tommaso Saccenti

Para: dirección de seguridad de la información del Banco Santander España

Clasificación del documento: confidencial / uso interno

1. RESUMEN EJECUTIVO

A petición de la dirección del banco santander, se ha realizado una auditoría dirigida a los mecanismos de autenticación basados en contraseñas de la entidad financiera. El objetivo fue verificar la efectividad y el cumplimiento de la actual política de seguridad de la información. El resultado del análisis técnico indicó un riesgo crítico estructural, evidenciando que la política documentada no está garantizada por controles de sistema (enforcement), lo que resulta en el incumplimiento total de las directrices de complejidad por parte de los usuarios finales, permitiendo a los atacantes acceder a las cuentas y áreas correlacionadas.

El presente documento tiene como objetivo dar respuesta a la consulta realizada por su entidad financiera respecto a la eficacia y el nivel de cumplimiento de su actual política de seguridad de contraseñas. La política vigente establece que las contraseñas deben tener:

Un mínimo de 8 caracteres.

Al menos un carácter de los siguientes tres grupos:

Letras (mayúsculas y minúsculas).

Caracteres numéricos (0-9).

Símbolos (! @ # $ % & * ^ ( ) - = { } [ ] \ : ; < > ? , . /).

Se nos ha informado que actualmente no existe un mecanismo técnico que fuerce el cumplimiento de estas reglas en los sistemas de información, dependiendo exclusivamente del factor humano. Se ha procedido a auditar tres cuentas de usuario bajo sospecha de incumplimiento.

2. METODOLOGIA E PADRÕES DE AVALIAÇÃO

Para verificar la robustez de las contraseñas almacenadas (cifradas mediante un algoritmo de hashing), se emplean técnicas de auditoría de seguridad de credenciales (o Password Cracking). Al no contar con mecanismos de bloqueo, los hashes pueden ser sometidos a procesos computacionales para recuperar el texto plano original, demostrando así su debilidad.

Las técnicas teóricas aplicadas para este análisis incluyen:

Ataque de diccionario: comparación masiva contra palabras de diccionarios de idiomas.

Ataque de fuerza bruta y diccionario híbrido: uso de listas de senhas comprometidas a nivel mundial (ej. Rockyou.txt).

Ataque basado en reglas (targeted attack): mutación de información personal del usuario (nombres, fechas, apellidos) combinada con patrones comunes.

A análise foi pautada nas diretrizes de segurança e práticas da OWASP. As vulnerabilidades encontradas foram dimensionadas utilizando a metodologia CVSS v3.1 (Common Vulnerability Scoring System).

2.1 **MATRIZ DE CLASIFICACIÓN DE RIESGOS**

Nivel de Riesgo	**Impacto**	**Acción Exigida**
CRÍTICO	Compromiso total de cuentas sensibles, permitiendo el acceso no autorizado a los sistemas financieros.	Inmediata
ALTO	Facilidad para descubrir credenciales mediante ataques automatizados o ingeniería social básica.	Urgente (Hasta 15 días)
MEDIO	Riesgo teórico que puede ser explotado bajo circunstancias específicas.	Planificada
BAJO	Desviaciones de buenas prácticas con impacto aislado o mitigado por otros controles.	Monitorización

Evaluación Global del Control de Contraseñas: CRÍTICO (Puntuación CVSS v3.1 Estimada: 9.8 - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H) debido a la ausencia de restricciones técnicas (rate limit/lockout) y la falta de complejidad sistémica.

Detalle de Métricas CVSS v3.1

Bloque de Explotabilidad**:** AV:N (Vector de Ataque: Red) [Peso: 0.85]; AC:L (Complejidad del Ataque: Baja) [Peso: 0.77]; PR:N (Privilegios Necesarios: Ninguno) [Peso: 0.85]; UI:N (Interacción del Usuario: Ninguna) [Peso: 0.85].

S:U (Scope: Unchanged / Escopo: Inalterado)

Bloque de Impacto: S:U (Alcance: Inalterado); C:H (Confidencialidad: Alta) [Peso: 0.56]; I:H (Integridad: Alta) [Peso: 0.56]; A:H (Disponibilidad: Alta) [Peso: 0.56].

3. ANÁLISIS DE LAS CUENTAS SOSPECHOSAS

A continuación, se detalla el análisis de los tres perfiles proporcionados, indicando la técnica que comprometería la credencial y las reglas específicas de la Política de Seguridad que están siendo violadas.

Nombre usuario	Username	Contraseña
Manuel Jimen Ventoyk	mjimenven	26967c61a7f5442fb47861f812126ccf02a65bde
José María Quevedo Yuw	jmquevedo	b1b3773a05c0ed0176787a4f1574ff0075f7521e
Rafael Hidalgo Gasca	rhgasca	35a9c2444ec63ee39f3b214edb9011f32e624a28

Todos tienen 40 caracteres hexadecimales, por lo tanto SHA-1, HMAC-SHA1… solo caracteres (0–9) y (a–f), no tienen un prefijo (1, 6, etc.)

herramientas utilizadas. : https://hashes.com/en/decrypt/hash , https://crackstation.net/.

Kali linux jhon->

nano hashe.txt (2696….)->

/usr/sbin/john hashes.txt --format=raw-sha1 --wordlist=/usr/share/wordlists/rockyou.txt

Using default input encoding: UTF-8

Loaded 3 password hashes with no different salts (Raw-SHA1 [SHA1 256/256 AVX2 8x])

Warning: no OpenMP support for this hash type, consider --fork=3

Press 'q' or Ctrl-C to abort, almost any other key for status

qwerty (?)

vituperio (?)...

En el caso de la última contraseña, sabemos que tiene 8 marcadores de posición. Luego podemos usar otros comandos a través de la terminal.

/usr/sbin/john hashes.txt --format=raw-sha1 --mask=?l?l?l?l?l?l?l?l

/usr/sbin/john hashes.txt --format=raw-sha1 --mask=?w?w?w?w?w?w?w?w

O brute force

/usr/sbin/john hashes.txt --format=raw-sha1 --incremental

/usr/sbin/john hashes.txt --format=raw-sha1 --incremental=All

hashcat con.:

└─$ hashcat -m 100 -a 3 hashes.txt --custom-charset1=abcdefghijlmnopqrstuvxz12345 ?1?1?1?1?1?1?1?1 -O

hashcat (v7.1.2) starting

35a9c2444ec63ee39f3b214edb9011f32e624a28:aaeiao5

Session.....: hashcat

Status.....: Exhausted

Hash.Mode.....: 100 (SHA1)

Hash.Target.....: hashes.txt

Time.Started.....: Fri Sep 11 14:06:12 2026 (0 secs)

Time.Estimated...: Fri Sep 11 14:06:12 2026 (0 secs)

Kernel.Feature...: Optimized Kernel (password length 0-55 bytes)

Guess.Mask.....: ?1?1?1?1?1?1?1 [7]

Guess.Charset....: -1 aeio250, -2 N/A, -3 N/A, -4 N/A, -5 N/A, -6 N/A, -7 N/A, -8 N/A

Guess.Queue.....: 1/1 (100.00%)

Speed.#01.....: 86758.5 kH/s (2.99ms) @ Accel:1024 Loops:256 Thr:1 Vec:8

Recovered.....: 1/3 (33.33%) Digests (total), 1/3 (33.33%) Digests (new)

Progress.....: 823543/823543 (100.00%)

Rejected.....: 0/823543 (0.00%)

Restore.Point....: 2401/2401 (100.00%)

Restore.Sub.#01..: Salt:0 Amplifier:256-343 Iteration:0-256

Candidate.Engine.: Device Generator

Candidates.#01...: ei2eeea -> o5i5o5o

Hardware.Mon.#01.: Util: 3%

Started: Fri Sep 11 14:06:09 2026

Stopped: Fri Sep 11 14:06:13 2026

3.1. Usuario: Manuel Jimen Ventoyk (mjimenven)

Contexto: El usuario ha utilizado una palabra rara del diccionario de la Real Academia de la Lengua Española (RAE). “no se ha complicado la vida y ha puesto como contraseña una palabra rara del diccionario de la Real Academia de la Lengua”.

Técnica: Este tipo de contraseña es vulnerable a un Ataque de Diccionario (Dictionary Attack) utilizando un diccionario estándar de idioma español.

Reglas Violadas:

Regra 2b (Números): Una palabra de diccionario puro carece de números.

Regra 2c (Símbolos): Carece de caracteres especiales.

* Es probable que esté escrita enteramente en minúsculas, careciendo de mayúsculas.

contraseña= vituperio

Del lat. mediev. vituperium.1. Baldón u oprobio que se dice a alguien. 2. Acción o circunstancia que causa afrenta o deshonra.

3.2. Usuario: José María Quevedo Yuw (jmquevedo)

Contexto: El usuario ha introducido una de las contraseñas "comunes que se ponen". Nota del auditor: El hash SHA-1 b1b3773a05c0ed0176787a4f1574ff0075f7521e corresponde a la contraseña "qwerty".

Técnica: Vulnerable a Ataque de Diccionario usando listas de contraseñas conocidas/filtradas (ej. Wordlists). Herramientas precomputadas (Rainbow Tables) rompen este tipo de hashes en milisegundos.

Reglas Violadas:

Regla 1 (Longitud): Al ser "qwerty", posee únicamente 6 caracteres (no cumple el mínimo de 8).

Regla 2b (Números): No contiene caracteres numéricos.

Regla 2c (Símbolos): No contiene caracteres especiales.

contraseña=qwerty

3.3. Usuario: Rafael Hidalgo Gasca (rhgasca)

Contexto: La contraseña es un juego de letras de su nombre/apellidos con un número al final.

Técnica: Altamente vulnerable a un Ataque Híbrido o de Fuerza Bruta Dirigido (Rule-based attack). Los atacantes extraen los datos públicos del usuario (Rafael, Hidalgo, Gasca) y aplican reglas automáticas (ej. agregar un dígito al final, cambiar la primera letra a mayúscula).

Reglas Violadas:

Regla 2c (Símbolos): La composición descrita confirma la ausencia de caracteres especiales.

*Regla 1 (Longitud): Dependiendo de las siglas utilizadas, podría no alcanzar los 8 caracteres.

contraseña=aaeiao5(7 caracteres solamente)

4. EVALUACIÓN DE VULNERABILIDADES Y CASOS AUDITADOS

La política oficial exige: Un mínimo de 8 caracteres y el uso de al menos tres grupos (mayúsculas/minúsculas, números y símbolos). La auditoría examinó los hashes y perfiles de 3 usuarios sospechosos, encontrando una violación total de la política.

Resultado General: Se confirma que los tres (3) usuarios auditados incumplen con la Política de Seguridad establecida por la entidad.

5. PLAN DE ORIENTACIÓN Y REMEDIACIÓN

Para que la institución esté alineada a los estándares y frameworks modernos de ciberseguridad (CIS Controls, NIST Cybersecurity Framework), las siguientes orientaciones de remediación deben ser conducidas, lo enumero a continuación.

Enforcement Sistémico: Configurar políticas de control en el Active Directory, Azure AD o IdP corporativo que rechacen técnica y automáticamente cualquier intento de registro de

contraseñas que no obedezca a los criterios mínimos de tamaño (8+) y complejidad (alfanuméricos + símbolos), y ni repetición de guarismos.

Corrección urgente: Invalidar inmediatamente las contraseñas de la tabla actual, obligando a todos los usuarios a restablecer sus credenciales en su próximo inicio de sesión.

Filtro de Contraseñas Comprometidas: Integrar la política de contraseñas a una lista dinámica de contraseñas comprobadamente filtradas (ej: integración con la API del Have I Been Pwned Pwned Passwords).

Solución de la causa raíz: Implementar una validación estricta en el código del backend durante la creación y el restablecimiento de contraseñas, impidiendo físicamente que las contraseñas débiles lleguen a la base de datos.

Mitigación arquitectónica: Abandonar el algoritmo SHA-1. Reemplazar el sistema de almacenamiento de contraseñas con algoritmos modernos de derivación de claves adaptativas que apliquen valores aleatorios únicos para cada usuario y tengan un factor de trabajo configurable para dificultar los ataques de fuerza bruta sin conexión.

Descontinuación de la Autenticación de Factor Único (MFA/2FA): Dada la naturaleza de las operaciones de la Entidad Financiera, el acceso basado apenas en contraseñas representa un fallo crítico arquitectural. Es obligatoria la implantación de Autenticación Multifactor (Tokens FIDO2, Aplicaciones Autenticadoras) para todo el perímetro tecnológico.

Lockout y Protección contra Fuerza Bruta: Garantizar que existan políticas de bloqueo temporal (Account Lockout) después de X intentos fallidos consecutivos para frenar ataques automatizados de descubrimiento y un temporizador de contraseña.